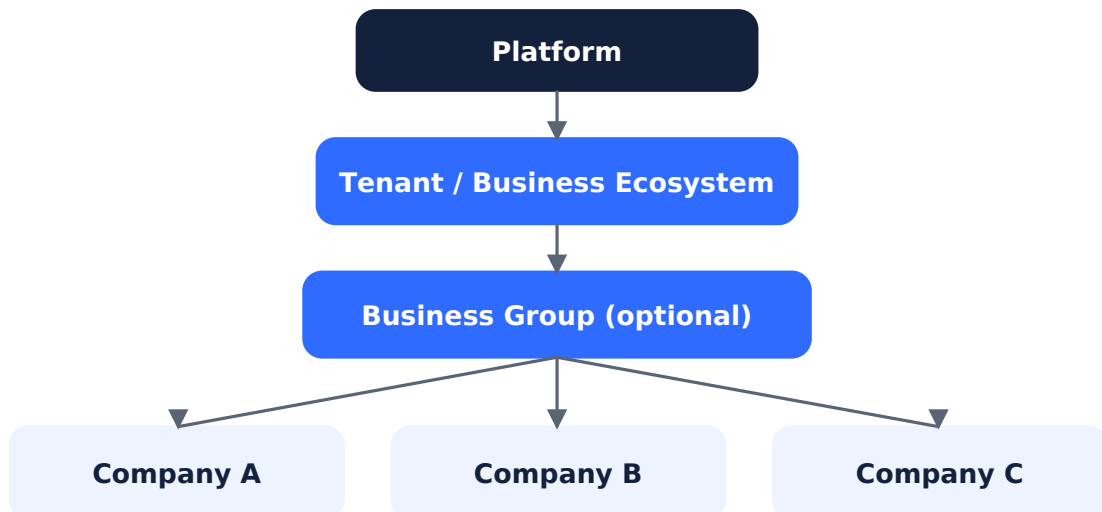


PRD_16

Business Group Scalability and Multi-Entity Operating Model

Construction OS

Full product and engineering specification for scaling from one independent company to a business group with many legal entities, shared services, cross-company users, consolidated reporting, and controlled collaboration.



Primary design constraint: introduce Group scalability without changing or weakening the current Company user model.

0. Document Control

Field	Value
Document	PRD_16 - Business Group Scalability and Multi-Entity Operating Model
Product	Construction OS
Purpose	Add optional group-level scalability while preserving current single-company behavior.
Compatibility	Additive and backward-compatible with all current Company users, roles, projects, contracts, finance, HR, documents, and tasks.
Precedence	This PRD extends group-related decisions from earlier PRDs. It does not replace Company-level governance unless explicitly stated.

Core rule

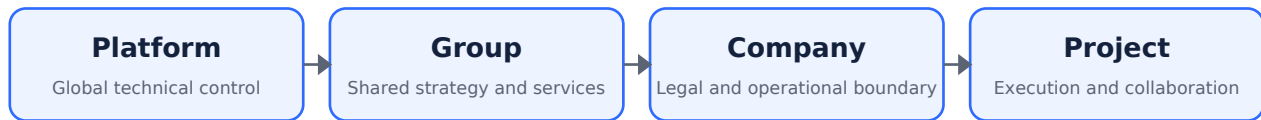
A Group is an optional coordination layer above Companies. A Company remains the legal, financial, operational, and default permission boundary. Existing users remain Company users unless additional Group access is explicitly granted.

1. Table of Contents

2. Executive Summary
3. Product Goals and Non-Goals
4. Non-Conflict and Backward-Compatibility Rules
5. Target Organizational Hierarchy
6. Identity, Membership, and Active Scope
7. Roles and Governance
8. Company Autonomy and Group Inheritance
9. Data Ownership and Visibility Classification
10. Shared Services and Centers of Excellence
11. Shared Resource Directory
12. Cross-Company Projects and Joint Ventures
13. Intercompany Work, Contracts, and Service Requests
14. Finance, Legal, and Consolidated Reporting
15. Clients, Contractors, Suppliers, and Counterparties
16. Documents, Search, Calendar, Notifications, and Tasks
17. User Experience and Navigation
18. Central Authorization and Policy Evaluation
19. Proposed Data Model
20. API, Events, and Integration Behavior
21. Migration from the Current Single-Company Architecture
22. Performance, Scalability, and Reliability
23. Security, Audit, and Privacy
24. Acceptance Criteria
25. Delivery Phases
26. Risks and Guardrails
27. Full Stack Implementation Checklist

2. Executive Summary

Construction OS must support both an independent company and a complex business group from the same codebase. The solution must not create a second product, a separate group portal, or a forked permission system.



Identity is global. Authority is scoped.

Company records remain company-owned.

Group views are consolidated read models, not merged source data.

Existing single-company users continue without workflow changes.

The recommended architecture keeps the existing tenant as the technical and billing boundary, introduces an optional Business Group layer, and preserves each Company as an independent legal and operational workspace.

- Single-company mode remains unchanged. Users continue to log in, see their company, and use the same modules and permissions.
- Group mode is additive. It adds consolidated views, shared services, cross-company assignments, and group governance.
- Company data is never silently merged. Group dashboards aggregate authorized data from company-owned records.
- One person may hold different roles in different companies. Access is calculated from the active scope and record context.
- Shared resources are linked, not duplicated. A person, contractor, supplier, or template may be available across companies while each company keeps its own relationship and records.

Strategic outcome

The platform becomes the operating center for a business ecosystem: one identity, one navigation model, one permission engine, and one audit system across many businesses, while preserving legal separation and company autonomy.

3. Product Goals and Non-Goals

Goals

- Allow one tenant to contain one independent company or a group with many companies.
- Preserve every existing Company user, role, permission, record, and workflow.
- Enable Group Owners and authorized Group Admins to coordinate multiple companies.
- Support shared departments and Centers of Excellence serving multiple companies.
- Support company-specific and group-level users without duplicate accounts.

- Provide consolidated dashboards without exposing restricted company details.
- Support cross-company projects, internal service requests, and joint ventures.
- Keep Finance, HR, Legal, contracts, documents, and audit records separated by legal entity.
- Scale to large groups without creating tenant-specific code branches.

Non-goals

- This PRD does not merge company accounting ledgers.
- This PRD does not remove Company Owner or Company Admin authority.
- This PRD does not make all group data visible to all group users.
- This PRD does not automatically move users or records between companies.
- This PRD does not require every tenant to activate Group mode.
- This PRD does not define external customer or public marketplace behavior.

4. Non-Conflict and Backward-Compatibility Rules

GRP-001 - Every existing tenant with one company must continue operating in Single-Company Mode with no mandatory Group screens or actions.

GRP-002 - Every existing user must retain the same Company membership, role, department, assigned projects, and record access after migration.

GRP-003 - The introduction of GroupMembership must not replace CompanyMembership. Group access is an additional scope.

GRP-004 - Company roles remain valid and authoritative inside the Company. Group roles must not silently grant unrestricted access to private company records.

GRP-005 - Existing URLs and record IDs should remain valid or be redirected without data loss.

GRP-006 - Existing Company Owners remain owners of their companies. No automatic ownership transfer occurs.

GRP-007 - Single-company users should not see a company switcher when there is nothing to switch.

GRP-008 - Company records keep their original company_id and legal identity.

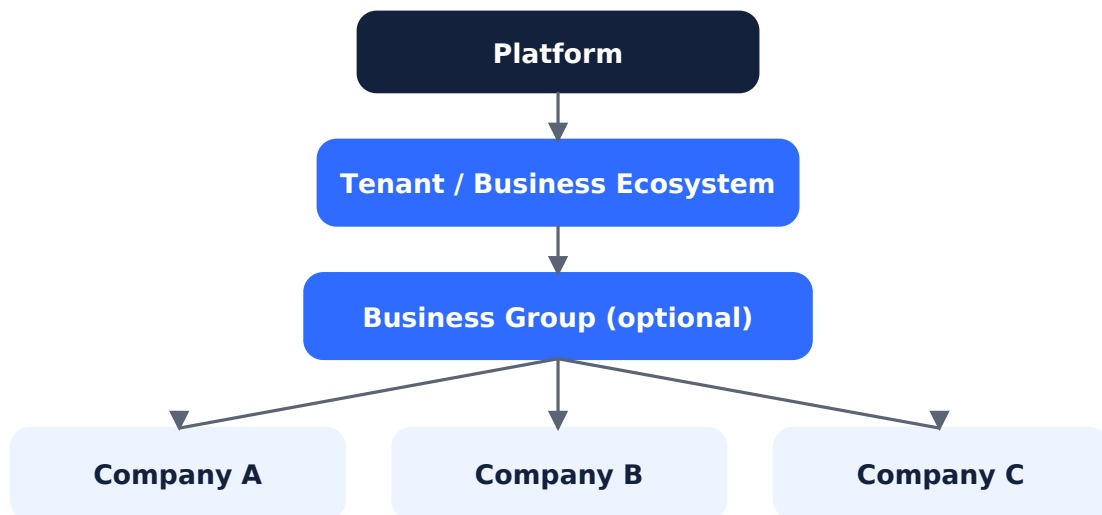
GRP-009 - No Group feature may weaken existing HR, Finance, Legal, contract, document, or support-access restrictions.

GRP-010 - A feature flag must permit gradual activation of Group mode per tenant.

Compatibility principle

The migration must feel invisible to an independent company. Group functionality appears only when a tenant contains or activates more than one company, or when a user receives Group-level responsibility.

5. Target Organizational Hierarchy



Hierarchy definitions

- Platform: the SaaS environment governed by Super Platform Admin and Platform Admin.
- Tenant / Business Ecosystem: the technical isolation, subscription, storage, and billing boundary.
- Business Group: an optional operating and governance layer containing one parent company and one or more child or affiliated companies.
- Company: the legal and operational entity that owns projects, contracts, finances, HR records, and official documents.
- Department: a company-level or group-shared organizational service.
- Project: an execution workspace owned by one company or explicitly shared across companies.
- Unit: a real estate or project asset governed by its project and owning company.

Independent company behavior

An independent company remains represented as one tenant with one company. The Group layer may be absent or represented by a hidden system wrapper. The user interface must not introduce unnecessary group terminology.

Business group behavior

A group tenant exposes Group Dashboard, Company Switcher, Shared Services, Consolidated Search, and authorized cross-company views. Each company remains separately addressable.

6. Identity, Membership, and Active Scope

One global identity

A human user has one platform identity and may have multiple scoped memberships. Duplicate user accounts for each company are prohibited unless required by a verified legal or security policy.

Membership layers

Layer	Purpose	Example
Platform identity	Authentication, profile, security, external integrations	One login for the person
Group membership	Group-wide responsibility or shared service role	Group Legal Manager

Layer	Purpose	Example
Company membership	Authority inside a legal entity	Finance Manager in Company B
Department membership	Operational team membership	Architecture Department
Project assignment	Record-specific project participation	Reviewer on Project X

GRP-011 - A user may have a different role, department, and permission set in each company.

GRP-012 - The active company or group scope must be explicit in the session and visible in the interface.

GRP-013 - Backend authorization must never infer the active company by selecting the first company in the tenant.

GRP-014 - Switching active scope must refresh permissions, navigation, dashboard queries, search scope, and notification context.

GRP-015 - A user with one company membership receives the current experience without a visible scope switcher.

GRP-016 - A Group-level user may be assigned to all companies by default, but child-company restrictions must be enforceable except against the unrestricted Parent Company Owner.

GRP-017 - A Group user may be restricted from a child company by that child Company Owner or Company Admin when permitted by existing governance.

GRP-018 - Leaving one company must not automatically remove the user from other companies or the Group.

7. Roles and Governance

Governance model

- Parent Company Owner: highest business authority across the Group and child companies, consistent with earlier decisions.
- Group Admin: delegated group-level administrator with permissions assigned by the Parent Company Owner.
- Company Owner: highest authority inside a company when the company is independent; in a group, the parent ownership model applies as already defined.
- Company Admin: administers a company but cannot exceed Owner restrictions.
- Group Shared-Service Manager: manages a shared function such as Legal, HR, Procurement, Finance, IT, BIM, or Architecture.
- Company user: retains existing company role and access.
- Platform Admin: remains technical SaaS governance and does not become a business Group administrator.

Role conflict rule

A Group role and Company role are evaluated together, but the result is constrained by the active company, record ownership, explicit restrictions, and sensitive-data policies. Group responsibility is not equivalent to universal data access.

GRP-019 - Only the Parent Company Owner or authorized Group Admin may create, remove, or restructure child companies, consistent with prior governance.

GRP-020 - Company Owners and Company Admins retain control over company operations and local memberships within established limits.

GRP-021 - Group roles must be permission bundles, not hard-coded bypasses.

GRP-022 - Every role assignment, restriction, delegation, and revocation must be audited.

GRP-023 - No Group Admin may modify the Parent Company Owner account unless explicitly permitted by an existing higher-level rule.

GRP-024 - Platform Admin and Group Admin must remain separate identities and permission domains.

8. Company Autonomy and Group Inheritance

Inheritance model

Group configuration may provide defaults, but a company remains the operational boundary. Each configuration item must declare whether it is enforced, inherited with override, or local-only.

Policy mode	Behavior	Example
Enforced by Group	Company cannot override	Security policy, mandatory retention
Inherited with override	Company starts with Group default and may customize	Task templates, approval thresholds
Company local	No Group inheritance	Local project folder arrangement

GRP-025 - Inherited settings must store their source and effective value.

GRP-026 - The interface must show whether a setting is Group-enforced, inherited, or locally overridden.

GRP-027 - Changing a Group default must not overwrite a company override.

GRP-028 - High-impact Group policy changes must show affected companies before confirmation.

GRP-029 - Company-specific custom features from PRD_11 remain tenant-isolated and must declare whether they are compatible with Group scope.

9. Data Ownership and Visibility Classification

Every record must have an explicit ownership scope

Scope	Meaning	Examples
Platform-owned	Technical SaaS configuration	Feature catalog, release versions
Group-owned	Shared operational or governance record	Group policy, shared standard, group department
Company-owned	Legal and operational source record	Contract, invoice, employee HR record
Project-shared	Owned by one company but shared to approved participants	Joint venture project documents
Relationship record	Company-specific relationship to a shared identity	Supplier terms for Company B

GRP-030 - All operational tables must contain tenant_id and an explicit owning scope, normally company_id.

GRP-031 - Group dashboards must query authorized company records and aggregate them into read models; they must not transfer ownership.

GRP-032 - Sensitive Company records must not become Group-visible merely because the company belongs to a Group.

GRP-033 - Cross-company links must be explicit, permission-checked, and auditable.

GRP-034 - A record may have one source owner and many authorized viewers, but not multiple conflicting source owners.

GRP-035 - Deleting or removing a child company must follow previously defined record-transfer and Platform Admin approval rules.

10. Shared Services and Centers of Excellence

Shared services

A Group may create departments that serve multiple companies, such as Group Finance, Legal, Procurement, Architecture, BIM, IT, HR, Marketing, Fleet, or Facility Management.

Operating model

- A shared department exists once at Group level.
- Its users receive Group membership plus company access only where required.
- Companies may submit service requests to the shared department.
- The request creates tasks, deadlines, documents, comments, approvals, and audit entries using the shared core engines.
- The company retains ownership of its project, contract, financial, HR, and legal records.
- The shared department receives only the access necessary to perform the service.

GRP-036 - A company may use a Group shared service, its own local department, or both.

GRP-037 - Shared-service users must not receive unrelated access to the requesting company.

GRP-038 - Each service request must identify requesting company, service department, responsible users, SLA, linked records, status, and outcome.

GRP-039 - A shared service may be assigned to one company, selected companies, or the entire Group.

GRP-040 - Company-specific service rules may override Group defaults only when the policy mode allows it.

11. Shared Resource Directory

Resource model

The platform must separate a shared identity from a company-specific relationship. This avoids duplicates without merging legal or financial records.

Resource	Shared identity	Company-specific relationship
Employee	Person profile and authentication	Role, salary, contract, department, leave
Client	Identity and general contacts	Company contracts, units, payments, notes
Contractor	Legal identity and profile	Company contracts, evaluations, payments
Supplier	Legal identity and catalogue	Company terms, quotations, purchase history
Equipment / Vehicle	Asset master identity	Owning company, assignment, cost, maintenance

GRP-041 - A shared resource must have a canonical identity and one or more scoped relationship records.

GRP-042 - Company users see only the relationship data permitted in their company.

GRP-043 - Group users may search shared identities only when authorized; financial, HR, and legal relationship details remain scoped.

GRP-044 - Duplicate detection may suggest a match but must not merge records automatically.

GRP-045 - A resource can be Group-available, company-only, or project-specific.

12. Cross-Company Projects and Joint Ventures

Project ownership

Every project must have one owning company. Additional Group companies or joint-venture partners may participate through explicit project participation records.

Participation types

- Lead company
- Participating Group company
- Internal service provider
- Joint venture partner
- External contractor or consultant

GRP-046 - The project owner controls the official project record and default access.

GRP-047 - A participating company receives only the project sections, tasks, documents, contracts, and financial data explicitly shared with it.

GRP-048 - Project participants may have project roles independent of their normal company role.

GRP-049 - Joint venture access must be deny-by-default and record-specific.

GRP-050 - Cross-company project users must see their own company context and the project owner clearly.

GRP-051 - Project audit records must identify both the acting user's membership scope and the owning company.

GRP-052 - Cross-company tasks and comments use the existing Task and Comment engines, not duplicate collaboration modules.

13. Intercompany Work, Contracts, and Service Requests

Internal companies as counterparties

One Group company may provide services to another and should be represented as an internal counterparty without losing legal separation.

- Company A may request design work from Company B.
- Company B may issue an intercompany proposal or contract.
- Tasks, documents, approvals, invoices, and payments remain owned by their respective companies.
- Shared identifiers allow both sides to navigate the relationship without duplicating records.
- The platform must visibly distinguish internal Group business from external business.

GRP-053 - Intercompany agreements must have two legal company parties and clear record ownership.

GRP-054 - Each company may maintain its own accounting representation of the transaction.

GRP-055 - One company's invoice must not be edited through the other company's record.

GRP-056 - Intercompany workflow status may be synchronized through events while source documents remain immutable to the counterparty.

GRP-057 - Approvals must follow each company's authority rules.

GRP-058 - The consolidated Group view must eliminate duplicate presentation of the same intercompany exposure without altering legal source records.

14. Finance, Legal, and Consolidated Reporting

Legal separation

Each Company keeps independent contracts, invoices, payments, payroll, tax records, bank accounts, budgets, and financial approvals. Group reporting is derived, not transactional.

Consolidated reporting

- Authorized Group users may view consolidated KPIs across selected companies.

- The system must preserve source currency and support a reporting currency.
- Every consolidated number must be drillable to permitted company records.
- Restricted company values must not be loaded for unauthorized users.
- Intercompany activity must be identifiable for reporting and elimination logic.

GRP-059 - Company Finance data remains company-owned and permission-restricted.

GRP-060 - Group Finance access must be explicitly granted and may vary by company.

GRP-061 - Consolidated dashboards must use permission-safe read models.

GRP-062 - Financial values must use Decimal and preserve currency, exchange-rate source, and valuation date.

GRP-063 - Legal documents remain owned by the contracting company.

GRP-064 - A Group Legal team may review multiple companies only through granted company or record access.

GRP-065 - Group totals must never overwrite company source values.

15. Clients, Contractors, Suppliers, and Counterparties

Identity reuse without relationship leakage

The same client, contractor, or supplier may work with many Group companies. The platform should avoid duplicate identity records while keeping every company's contracts, payments, evaluations, and comments separate.

GRP-066 - A counterparty profile may show a Group summary only to authorized Group users.

GRP-067 - Company users see only their company's relationship unless explicit cross-company access exists.

GRP-068 - Clickable contracts must open the source contract in its owning company context.

GRP-069 - Client and contractor financial totals must remain calculated from company-owned Finance records.

GRP-070 - Company-specific notes and evaluations must not be exposed to other Group companies by default.

GRP-071 - Shared contact changes must be versioned and auditable because they may affect multiple companies.

16. Documents, Search, Calendar, Notifications, and Tasks

Documents

- Group library for standards, policies, templates, brand assets, and shared technical references.
- Company repositories remain separate.
- Project and contract documents retain source ownership and revision rules.
- Group users may receive linked access, not copied files.

Search

- Single-company users search their current company as today.
- Multi-company users may search Active Company or Authorized Group Scope.
- Every result must display owning company and record type.

- Search indexing must apply permission filters before result delivery.

Calendar and notifications

- Personal calendars remain private as defined in PRD_9.
- Group calendar views contain only authorized shared events and aggregated availability.
- Notifications must state the relevant company and project.
- Users can filter notifications by company and scope.

Tasks

- One Task engine supports company, shared-service, intercompany, and cross-company project work.
- Task assignment must verify the assignee is available in the relevant company or project scope.
- Task access must not grant unrelated company access.

17. User Experience and Navigation

Progressive complexity

The interface must remain simple for users who operate in one company. Group complexity appears only to users who need it.

GRP-072 - Single-company users retain the existing company dashboard and navigation.

GRP-073 - Multi-company users receive a Company / Group Scope Switcher in the global header.

GRP-074 - The switcher must show Group, company name, legal entity indicator, role, and unread work count.

GRP-075 - Every page must show the active company context when a destructive, financial, legal, or HR action is possible.

GRP-076 - Group Dashboard must be a separate read experience, not a replacement for Company Dashboard.

GRP-077 - Role-specific Creative Themes may change when the active role changes, consistent with PRD_9.

GRP-078 - Deep links must include or resolve the correct company scope.

GRP-079 - A user opening a record outside the active company may be offered a safe context switch after authorization.

18. Central Authorization and Policy Evaluation

Required authorization context

- user_id
- tenant_id
- active_group_id, when applicable
- active_company_id
- active membership and role
- department memberships
- project participation
- record owner and record scope
- shared-service assignment
- temporary Platform Admin support access
- explicit restrictions or grants

Policy decision

Every backend operation must evaluate action + resource + context. The frontend may hide controls, but the backend is authoritative.

GRP-080 - JWT or session claims must not be the sole source of current membership authority.

GRP-081 - Role and membership changes must invalidate or refresh active sessions.

GRP-082 - All referenced IDs must be verified against tenant and owning company before writes.

GRP-083 - Group access must never use broad tenant membership as a substitute for company authorization.

GRP-084 - Policy decisions should be centralized and testable.

GRP-085 - Permission-safe selectors must prevent restricted fields from being queried.

19. Proposed Data Model

Core entities

Entity	Purpose	Key fields
Tenant	Technical and billing boundary	id, mode, subscription, region
BusinessGroup	Optional group governance	id, tenant_id, parent_company_id, status
Company	Legal entity	id, tenant_id, group_id nullable, legal metadata
User	Global identity	id, auth identity, profile, security state
GroupMembership	Group-level authority	user_id, group_id, role, status
CompanyMembership	Company-level authority	user_id, company_id, role, department, status
SharedDepartment	Center of Excellence	group_id, service type, covered companies
CompanyParticipation	Company participation in project/service	company_id, resource_type, resource_id, role
SharedIdentity	Canonical counterparty/resource identity	type, tenant_id, canonical fields
CompanyRelationship	Scoped relationship to shared identity	company_id, shared_identity_id, terms, status

Schema guardrails

- Operational records should include tenant_id and owning_company_id.
- Group-owned records use group_id and must declare whether they are inherited or enforced.
- Cross-company association tables must include both company IDs and explicit participation type.
- Foreign keys and unique constraints must prevent cross-tenant links.
- Indexes must cover tenant_id, company_id, group_id, status, updated_at, and frequently queried relationship keys.

20. API, Events, and Integration Behavior

API context

Every request must carry or resolve an authorized active company or group scope. The API must reject ambiguous scope for sensitive actions.

Domain events

- CompanyAddedToGroup

- CompanyRemovedFromGroup
- GroupMembershipGranted
- CompanyMembershipRestricted
- SharedServiceRequested
- SharedServiceAssigned
- CrossCompanyProjectParticipantAdded
- IntercompanyContractActivated
- GroupPolicyChanged
- CompanyOverrideChanged

Event rules

- Events include tenant, group, owning company, actor, correlation ID, and source record.
- Events must be idempotent.
- Cross-module consumers must not directly alter source-owned records.
- Use an outbox pattern so database changes and event publication remain consistent.
- Group dashboards may be updated asynchronously through read models.

21. Migration from the Current Single-Company Architecture

Migration objective

Move from tenant-level membership assumptions to explicit company context without changing the user's current experience.

Recommended migration sequence

- 1 Add Group-capable schema without enabling Group UI.
- 2 Create or confirm CompanyMembership rows for every existing tenant user.
- 3 Backfill owning_company_id on operational records using the existing company association.
- 4 Replace any 'first company in tenant' logic with explicit active_company_id resolution.
- 5 Introduce a session security version so role and membership changes refresh authorization.
- 6 Add central policy checks and cross-tenant/company validation.
- 7 Create Group entities only for tenants that activate Group mode.
- 8 Release Company Switcher only to users with multiple authorized scopes.
- 9 Add Group Dashboard as permission-safe read models.
- 10 Enable shared services and cross-company projects in later phases.

Zero-disruption requirements

- No existing user must be asked to recreate an account.
- No existing company must be forced to configure a Group.
- No existing record should receive a different legal owner.
- Existing company URLs and bookmarks should remain usable.
- Migration scripts must be repeatable, logged, and reversible before production cutover.

22. Performance, Scalability, and Reliability

Scale targets

- 1 to 1,000 companies in a tenant.
- Hundreds of thousands of users and memberships across the platform.
- Millions of operational records per large tenant.
- Group dashboards across many companies without full-table synchronous scans.

GRP-086 - Use indexed company and group partition keys on all large tables.

GRP-087 - Consolidated dashboards should use incremental read models or materialized aggregates.

GRP-088 - Large Group searches must be paginated and permission-filtered server-side.

GRP-089 - Background jobs must handle consolidation, indexing, notifications, and inheritance propagation.

GRP-090 - Company-level operations should not become slower because Group mode exists.

GRP-091 - Failure in one company-specific integration or custom feature must not affect other companies.

GRP-092 - Backups and restoration must support company-level recovery where technically feasible while preserving tenant consistency.

23. Security, Audit, and Privacy

Security principles

- Deny by default across company boundaries.
- Least privilege for Group shared-service users.
- Explicit grants for cross-company projects and records.
- Separate Platform Admin support access from Group business authority.
- Immutable audit records for every scope switch, membership change, cross-company share, policy change, and data access escalation.
- Sensitive fields excluded at query level, not hidden only in UI.

GRP-093 - Audit logs must record acting user, active membership, group, company, record owner, action, before/after values, timestamp, and support-access state.

GRP-094 - Group-level exports must apply the same field and record permissions as interactive views.

GRP-095 - A user must not infer restricted company activity from counts, search suggestions, URLs, or notification metadata.

GRP-096 - Cross-company sharing must show a clear access summary before confirmation.

GRP-097 - Removing access must immediately affect new requests and refresh active sessions.

GRP-098 - Data residency and retention policies may be enforced at tenant or company level depending on legal requirements.

24. Acceptance Criteria

- AC-01 - An existing single-company user logs in after migration and sees the same company dashboard, modules, permissions, and records.
- AC-02 - A user belonging to three companies can switch scope and receives the correct role, navigation, and data for each company.
- AC-03 - A Company Admin cannot view another company merely because both belong to the same Group.

- AC-04 - An authorized Parent Company Owner can view consolidated Group dashboards and drill into permitted company records.
- AC-05 - A Group shared-service Architect can complete an assigned request without receiving unrelated Finance or HR access.
- AC-06 - A company contract, payment, and HR record remain owned by that company and are not merged into Group storage.
- AC-07 - A cross-company project exposes only explicitly shared project sections.
- AC-08 - A shared contractor identity can be reused while contract values and evaluations remain company-specific.
- AC-09 - Changing a Group default does not overwrite an existing company override.
- AC-10 - Removing a Group membership does not remove valid independent Company memberships.
- AC-11 - Every cross-company action produces an immutable audit record with correct company context.
- AC-12 - Single-company performance remains within agreed baseline after Group-capable schema deployment.
- AC-13 - No backend action uses the first company in a tenant as authorization context.
- AC-14 - All cross-reference IDs are validated for tenant and company ownership.
- AC-15 - Group mode can be enabled per tenant without a separate deployment or code fork.

25. Delivery Phases

Phase	Scope	Exit condition
1. Foundation	Explicit company context, CompanyMembership, policy fixes, data backfill	Current company mode stable and secure
2. Group Core	BusinessGroup, GroupMembership, scope switcher, Group governance	Multiple companies operate safely in one tenant
3. Consolidated Views	Group dashboard, search, directories, read models	Authorized group visibility without data merging
4. Shared Services	Centers of Excellence, service requests, shared tasks	Group departments serve selected companies
5. Cross-Company Operations	Shared projects, intercompany work, JV access	Controlled operational collaboration
6. Advanced Enterprise	Intercompany eliminations, regional policy, advanced integrations	Large-group production readiness

Release rule

Do not begin Group Dashboard or shared-service work until explicit company context and tenant/company authorization defects identified in Code Audit 1 are resolved.

26. Risks and Guardrails

Risk	Impact	Guardrail
Tenant-wide access treated as company access	Cross-company data exposure	Central policy engine with explicit company context
Group roles become universal bypasses	Sensitive data leakage	Permission bundles plus record-level checks

Risk	Impact	Guardrail
Duplicated client/contractor data	Conflicting truth	Shared identity + company relationship model
Group dashboards query live source tables	Poor performance	Incremental permission-safe read models
Inheritance overwrites local configuration	Operational disruption	Source-aware effective configuration
Custom code forks per company	Unmaintainable platform	Feature flags, extension points, versioned modules
Company users experience unnecessary complexity	Adoption failure	Progressive disclosure and hidden Group UI in single-company mode

27. Full Stack Implementation Checklist

Architecture

- ☐ Tenant remains the technical boundary; Company remains the operational boundary.
- ☐ Optional BusinessGroup entity added without changing independent-company behavior.
- ☐ Explicit active_company_id used in all sensitive server operations.
- ☐ No tenant-level shortcut grants company access.

Backend

- ☐ Central authorization service implemented.
- ☐ Company and Group ownership validated for all foreign IDs.
- ☐ Domain events and outbox implemented for cross-module effects.
- ☐ Membership changes invalidate current authorization state.
- ☐ Permission-safe read models created for Group dashboards.

Database

- ☐ CompanyMembership and GroupMembership separated.
- ☐ Operational records backfilled with owning_company_id.
- ☐ Shared identity and company relationship tables added.
- ☐ Indexes and foreign-key constraints added for scope fields.
- ☐ Financial and consolidated values use Decimal.

Frontend

- ☐ Single-company navigation remains unchanged.
- ☐ Scope switcher appears only when needed.
- ☐ Active company visible on sensitive actions.
- ☐ Group dashboard separated from Company dashboard.
- ☐ Every cross-company record displays its owning company.

Security and QA

- ☐ Cross-company authorization tests cover every module.
- ☐ Negative tests prove unauthorized company access is blocked.
- ☐ Migration tested on production-like copies.

- [] Audit entries validated for actor and scope.
- [] Performance baseline compared before and after Group schema.

Final engineering principle

One platform identity. Optional Group governance. Explicit Company authority. One source of truth per record. Shared services through controlled access. Consolidation through read models. No disruption to existing Company users.